Informe técnico · Entregable 2

Administración de base de datos aplicada sobre DBSuperHamburguesas

Proyecto 2 · TIIT3175.2 Bases de Datos III · Universidad Invenio · Ingeniería TICE Luis Alejandro Luna García · Alejandro Josué Rodríguez Zamora · Avril Madrigal Elizondo · Cesar Andrés Ubau Calvo 22 de septiembre de 2026

1. Objeto y alcance

El Entregable 1 fijó el estándar: un documento técnico-normativo, genérico, que establece qué reglas debe cumplir un servidor Microsoft SQL Server en la organización, con un catálogo de trece controles. Este informe documenta la otra mitad del trabajo: la aplicación de ese estándar sobre una base concreta, `DBSuperHamburguesas`, montada en una instancia real, y la evidencia que prueba cada control.

El alcance cubre configuración de la plataforma, modelo físico, seguridad y mínimo privilegio, protección de información sensible, auditoría, respaldo y recuperación a un punto en el tiempo, monitoreo, rendimiento y validación final. No cubre replicación ni alta disponibilidad por las razones que se exponen en la sección 7.

Restricción observada durante todo el trabajo: el modelo base es inmutable. No se renombró, eliminó ni alteró ninguna tabla, columna o restricción del diccionario de datos. Todo lo construido vive en un esquema administrativo separado y en el plano de permisos.

2. Plataforma

Parámetro	Valor verificado
Instancia	`EXPRESS2022`
Motor	SQL Server 2022, versión 16.0.1200.5, edición Express (64 bits)
Intercalación	`Modern_Spanish_CI_AS`
Autenticación	Modo mixto
Modelo de recuperación	Completo
Verificación de página	Activa
Archivo de datos	256 MB, crecimiento fijo de 64 MB
Archivo de registro	128 MB, crecimiento fijo de 32 MB

Dos de estos valores son condición de todo lo demás. El **modelo completo** es lo que hace existir el respaldo del registro de transacciones, y sin ese respaldo no hay recuperación a un instante exacto. La **verificación de página**

es lo que hace que la comprobación de integridad de los respaldos verifique algo: sin ella, el respaldo se toma igual y termina con éxito sin haber comprobado nada, que es una garantía falsa y por lo tanto peor que ninguna.

El **crecimiento fijo** en lugar de porcentual evita que cada expansión sea mayor que la anterior y que el archivo crezca de forma impredecible bajo carga.

Sobre la edición Express

La edición condiciona recursos, no funciones de auditoría. Se verificó contra la versión del motor —no contra el nombre de la edición— que el rastro de auditoría de servidor está disponible en todas las ediciones, y el de base de datos en todas desde SQL Server 2016 Service Pack 1. En consecuencia se empleó el mecanismo nativo y **no se tramitó ninguna excepción**, porque no existe limitación técnica que la justifique. Esta verificación es la que exige el control DBA-GOB-02.

Los topes que sí aplican —grupo de memoria intermedia de 1 410 MB, un procesador lógico, 10 GB por base— no afectan a ninguno de los mecanismos implementados, pero sí hacen que los tiempos absolutos medidos en la sección 9 no sean extrapolables a un ambiente productivo.

---

3. Modelo físico

Diecinueve tablas de negocio distribuidas en seis esquemas de dominio, más un séptimo esquema administrativo:

Esquema	Tablas
`catalogo`	Hamburguesa, Ingrediente, RecetaHamburguesa, TipoImpuesto, HamburguesaImpuesto
`ventas`	Cliente, EstadoPedido, Pedido, PedidoDetalle
`inventario`	ExistenciaIngrediente, TipoMovimientoInventario, MovimientoInventario
`rrhh`	Departamento, Puesto, Empleado
`proveedores`	Proveedor, ProveedorIngrediente
`contabilidad`	CuentaContable, MovimientoContable
`dba`	Objetivos de recuperación, configuración de respaldo, marca de incidente, evidencia de inventario, pruebas de autorización, mediciones de rendimiento

Cero objetos de negocio en el esquema por defecto. Esto no es una convención de orden: el esquema es la unidad sobre la que se concede y se retira el acceso. Porque el modelo está separado por dominios, cada rol se define contra un dominio completo. Si todo estuviera junto, el mínimo privilegio habría que construirlo tabla por tabla, y sería inauditable.

El esquema `dba` concentra toda la evidencia que genera este entregable dentro de la propia base, de modo que sea consultable y no dependa de documentos externos que se desactualizan.

---

4. Seguridad y mínimo privilegio

Medida	Valor
Roles de dominio	12 (consulta y gestión por cada esquema de negocio)
Usuarios nominativos	12
Membresías	13
Permisos concedidos	101, todos al rol
Permisos concedidos directamente a un usuario	0
Denegaciones comprobadas rol × objeto	60
Pruebas de autorización	15, todas con el resultado esperado

Decisiones de diseño

El permiso se concede al rol, nunca al usuario. Si una persona cambia de puesto, se le retira un rol y pierde exactamente ese conjunto de accesos, de forma verificable. Con permisos a nombre del usuario habría que revisar objeto por objeto para saber qué tenía, y siempre queda algo suelto.

El modelo es cerrado por omisión. Las sesenta denegaciones no son sesenta prohibiciones escritas: son el resultado de recorrer la matriz completa y comprobar que el permiso no está. Solo existe una denegación explícita en todo el modelo, sobre el esquema administrativo, y se aplica a nivel de esquema para que alcance también a los objetos que se creen en el futuro.

Los registros históricos no se borran. El historial de movimientos de inventario y los asientos contables reciben permiso de inserción pero no de borrado, ni siquiera desde el rol de gestión. Una corrección se hace con un asiento de reverso, que queda registrado.

Una nota que conviene anticipar

Bajo permisos a nivel de columna, una consulta con `COUNT(*)` falla con error 230 aunque el usuario tenga columnas concedidas, porque el motor evalúa el asterisco contra el objeto completo. No es un defecto del control: es la prueba de que opera a nivel de columna y no de tabla. Las pruebas positivas cuentan una columna concedida de forma explícita.

---

5. Protección de información sensible

Tres casos, resueltos con el mismo mecanismo: la concesión **enumera las columnas visibles**, y lo que no está en la lista queda fuera.

Caso	Objeto	Lo que el rol de consulta no ve
1	`catalogo.Ingrediente`	`CostoReferencia`
2	`rrhh.Empleado`	`Salario`, `Identificacion`, `FechaNacimiento`
3	`proveedores.ProveedorIngrediente`	`PrecioReferencia`

No hay vista intermedia que filtre columnas, y no hay prohibición explícita sobre los atributos sensibles. Es un modelo de lista blanca, y la diferencia es concreta: si mañana se agrega una columna nueva a la tabla de empleados, esa columna nace oculta. Con el modelo inverso —prohibir lo sensible— nacería expuesta, y nadie lo notaría hasta que fuera tarde.

---

6. Auditoría

El mecanismo tiene dos piezas: un **rastro de servidor** que escribe el archivo, y una **especificación de base de datos** que decide qué entra en él.

Categoría	Qué registra	Por qué
1	Modificaciones sobre `rrhh.Empleado`	Quién cambió un salario o una identificación, y cuándo
2	Alta, modificación y borrado de asientos en `contabilidad.MovimientoContable`	Un asiento contable no puede cambiar en silencio
3	Altas y bajas de membresía de roles	Es el control que protege a los otros dos: quien se agrega un rol para tocar algo deja el rastro antes

Cada evento registra los cuatro atributos que exige el enunciado: instante, usuario, objeto y operación, además de la sentencia literal.

No se audita todo, y es deliberado. Auditar todo no hace el sistema más seguro: produce un archivo que nadie lee y cobra un costo de escritura en cada operación. Se audita lo que cambia el estado o el privilegio. Las lecturas del salario no se auditan porque el permiso por columna ya las impide.

Configuración: destino en archivo —para que la evidencia sea una consulta reproducible y no una captura del visor de eventos—, 24 archivos de 64 MB, que cubren con holgura los doce meses de retención que el control DBA-SEG-04 adopta del requisito 10.5.1 de PCI DSS v4.0. Ante fallo de escritura se eligió continuar y no detener la instancia; la decisión se declara de forma expresa porque es una desviación del criterio más estricto, adecuada a un ambiente académico pero no a uno con información regulada.

Riesgo residual declarado: un miembro de `sysadmin` puede desactivar la auditoría. La mitigación es que esa desactivación queda registrada antes de que el rastro se detenga. Se acepta como inherente al modelo de privilegios del motor.

Resultado: las tres categorías con eventos reales generados y consultados — 6, 10 y 19 eventos respectivamente.

---

7. Respaldo, objetivos de recuperación y disponibilidad

Estrategia

Tipo	Frecuencia	Para qué
Completo	Diario	Punto de partida de toda restauración
Diferencial	Cada 6 horas	Acorta la recuperación sin multiplicar archivos
Registro	Cada 15 minutos	Es lo único que permite detenerse en un instante exacto

Objetivos

Objetivo	Valor	Fundamento
RPO	15 minutos	Es el volumen de pedidos que el personal del turno puede reconstruir desde los comprobantes físicos. Más allá de ese punto la reconstrucción manual deja de ser viable
RTO	120 minutos	Cabe en una jornada parcial y no arrastra el turno siguiente. La base sostiene la toma y el cobro de pedidos: caída, no se atiende ni se factura

Ambos valores, con su justificación, quedan almacenados en una tabla de la propia base y no en un documento aparte.

Evaluación de disponibilidad (control DBA-DIS-01)

La edición Express no ofrece grupos de disponibilidad Always On ni creación de reflejo de base de datos. La alternativa evaluada y adoptada es **respaldo y restauración**. Lo importante para el control es lo contrario de lo que suele hacerse: la estrategia de respaldo **no se redujo** por no contar con replicación, y tampoco se habría reducido de contar con ella. Un mecanismo de replicación protege contra la pérdida del servidor, no contra el error lógico: una actualización masiva equivocada se replica a la copia secundaria con la misma fidelidad que al original. Solo el respaldo permite revertirla.

---

8. Recuperación a un punto en el tiempo

Se provocó de forma deliberada un incidente lógico —una actualización masiva sin cláusula de filtro que dejó en cero las veinte filas de existencias— y se recuperó la base al instante previo.

Paso	Archivo	Modo
1	Completo	Sin abrir la base
2	Diferencial	Sin abrir la base
3	Registro 01	Completo: es íntegramente anterior al incidente
4	Registro 02	Detenido en la marca, y recién ahí se abre la base

La marca se registra en el momento del daño, no se estima al momento de restaurar. La restauración se hizo sobre una **base alterna**: la productiva no se tocó.

Resultado	Valor
Base dañada	20 filas con existencia en cero
Base recuperada	19 910 unidades, cero filas en cero
Coincidencia con el último estado íntegro registrado	Exacta
Tiempo de restauración	0,68 s
RTO declarado	120 minutos
Integridad	`DBCC CHECKDB` sin errores

La verificación no es que la restauración terminara sin error, sino que el dato afectado aparece con su valor previo. Una restauración que termina bien no prueba nada por sí sola.

---

9. Monitoreo y rendimiento

Informe de salud

Seis señales, elegidas con un solo criterio: **cada una tiene una acción asociada**. Una métrica que no cambia ninguna decisión no entra al informe.

Señal	Estado al 22 de septiembre	Lectura
Uso del registro de transacciones	2,22 %	Por debajo del 50 %: la cadena está liberando espacio
Espacio libre en archivos	92,43 % y 97,78 %	Muy por encima del umbral del 20 %
Sesiones activas	3, sin esperas	Normal
Transacciones abiertas	0	Normal
Bloqueos	0	Normal
Vigencia de respaldos	Los tres tipos dentro de su frecuencia	Normal

Optimización medida

Sobre la consulta de cierre comercial del trimestre se creó el índice `IX_Pedido_EstadoFecha`, con clave `(EstadoPedidoID, FechaPedido)` y columnas incluidas, de modo que la consulta se resuelve dentro del propio índice sin volver a la tabla.

Métrica	Antes	Después	Reducción
Lecturas lógicas	291	58	**80,07 %**
Tiempo de CPU	7 ms	5 ms	28,57 %
Tiempo transcurrido	6 ms	4 ms	33,33 %

La comparación se juzga por las lecturas lógicas, que no dependen de la memoria disponible ni de la carga del equipo. El índice cuesta 1 448 KB y se paga en cada escritura sobre la tabla; se justifica porque la consulta es recurrente y el optimizador lo usa por búsqueda de rango, no por recorrido.

---

10. Validación final

`09_Validacion.sql` ejecuta dieciocho comprobaciones sobre los trece controles del catálogo.

Momento	Comprobaciones	Cumplen	No cumplen	A revisar	Veredicto
2026-09-22 19:42	18	18	0	0	**AMBIENTE CONFORME**

La sección final ejecuta `DBCC CHECKDB` sobre la base productiva, sin errores de asignación ni de consistencia.

---

11. Incidencias encontradas y correcciones aplicadas

Se documentan porque forman parte del trabajo real y porque tres de ellas son defectos que habrían pasado inadvertidos si no se hubiera exigido evidencia de cada control.

#	Dónde	Síntoma	Causa	Corrección
1	`03_Auditoria.sql`	Cero eventos en las tres categorías; control en NO CUMPLE	La propiedad que devuelve la carpeta de respaldo **no incluye el separador final**, de modo que el patrón de archivo no correspondía a ninguno. La auditoría sí estaba grabando	Resolver la ruta desde el catálogo de la propia auditoría
2	`04_Backup.sql`	Error 3201, «Acceso denegado» al escribir los respaldos	La misma causa: el archivo apuntaba fuera de la carpeta de respaldos, donde la cuenta de servicio no escribe	Normalizar el separador antes de concatenar
3	`04_Backup.sql`	El script continuó pese al error y aplicó el incidente **sin respaldo del cual revertirlo**	Ausencia de una comprobación previa al bloque destructivo	Guarda que consulta el historial de respaldos y aborta si falta cualquiera de los tres tipos
4	`07_Rendimiento.sql`	Error 2560, «Parameter 1 is incorrect for this DBCC statement»	Se pasaba un identificador de objeto a una sentencia que solo admite identificador de plan	Resolver el identificador de plan desde el catálogo, con recorrido acotado
5	`07_Rendimiento.sql`	Lecturas lógicas en cero	Los contadores de sesión solo se consolidan cuando la petición termina: dentro de la misma ejecución devuelven el mismo valor antes y después	Medir sobre los contadores de la petición en curso
6	`09_Validacion.sql`	Un NO CUMPLE en el conteo de tablas: 19 obtenidas contra 18 esperadas	El valor esperado del script estaba equivocado; el diccionario de la sección 6 del enunciado define 19 tablas	Corregir el valor esperado a 19

La incidencia 3 obligó además a reparar el inventario, que había quedado en ceros sin respaldo. Se recuperó recalculando el sembrado original, que es determinista, y el total coincidió exactamente con el registrado antes del daño.

---

12. Conclusiones

1. Los trece controles del Entregable 1 tienen implementación verificable y evidencia registrada. El estándar no quedó como documento decorativo: fue la especificación contra la que se construyó.
2. El modelo de seguridad es cerrado por diseño y reversible: ciento un permisos, todos al rol, y una sola denegación explícita en todo el modelo.
3. La recuperación a un punto en el tiempo está probada sobre el dato, no sobre el mensaje de éxito, y dentro del objetivo declarado.
4. La auditoría registra lo que cambia estado o privilegio, con la retención que el control exige, y no más.

5. El modelo base quedó intacto. Esa es, en última instancia, la diferencia entre administrar una base de datos y rehacerla.

Anexo · Índice de evidencias

Código	Contenido
EV-00-01	Diagnóstico de la instancia y acreditación de capacidades
EV-02-01	Modelo de seguridad y mínimo privilegio
EV-03-01	Mecanismo de auditoría y eventos registrados
EV-04-01	Estrategia y cadena de respaldos
EV-04A-01	Reparación del inventario tras el incidente sin respaldo
EV-05-01	Acta de prueba de restauración a un punto en el tiempo
EV-06-01	Informe de salud de la base
EV-07-01	Medición de rendimiento antes y después del índice
EV-09-01	Cuadro de mando de validación final